

OKTA INTERVIEW STUDY GUIDE

Complete Technical Reference
IT Administrator · Identity & Access Management · MDM · Google Workspace

Prepared: June 13, 2026

CONFIDENTIAL — FOR PERSONAL USE ONLY

Table of Contents

1. Okta Onboarding Automation [\[Required\]](#)
2. Okta Offboarding [\[Required\]](#)
3. SAML vs SCIM [\[Required\]](#)
4. Integration Troubleshooting [\[Required\]](#)
5. RBAC Rule Logic [\[Required\]](#)
6. Google Workspace Administration [\[Required\]](#)
7. Microsoft 365 Exposure
8. MDM — macOS and Windows [\[Required\]](#)
9. Jira and Confluence [\[Required\]](#)
10. Asset Management and Procurement [\[Required\]](#)
11. Security Best Practices [\[Required\]](#)
12. Ticket Prioritization & Help Desk Communication [\[Required\]](#)
13. Interview Performance Tips
14. Quick Reference Card
15. Mock Q&A; — Practice Questions with Model Answers
16. Questions to Ask the Interviewer

1. Okta Onboarding Automation (End to End) [Required Skill]

Overview

Okta onboarding automation creates a seamless, repeatable workflow that begins the moment an employee record is created in your HRIS and ends with a staged laptop on day one. The goal is **zero manual steps for standard roles**.

Step 1 — HRIS as Source of Truth

- **BambooHR** or **Workday** holds the canonical employee record
- Fields that matter: name, email, department, title, location, start date, manager, employee type
- HRIS is the trigger point — nothing in Okta should happen before HRIS confirms the hire

Step 2 — Webhook / API Trigger

- HRIS fires a **webhook** on new employee record creation (or status change to 'Active')
- Webhook hits an automation layer: Okta Workflows, Workato, Zapier, or a custom middleware
- Trigger fires N days before start date (commonly 2–5 business days) for staging time

Step 3 — Data Mapping

- Map HRIS fields → Okta user profile attributes
- Examples: **department** → used in group rules, **location** → determines policy set, **employeeType** → contractor vs. FTE rules
- Mapping must be exact — attribute drift causes group rule failures

Step 4 — Automated Account Creation

- Okta creates user profile via **SCIM provisioning** or API call from automation layer
- Account is staged (not yet activated) until start date, or activated immediately depending on policy
- Activation email fires on day one, or a temp password is delivered via manager

Step 5 — Group Rules and RBAC Auto-Assignment

- Okta **Group Rules** evaluate attribute conditions and assign groups automatically
- Example rule: IF **department = Engineering** AND **employeeType = Employee** → assign group 'eng-team'
- Groups map to app assignments — joining a group grants access to all apps assigned to that group
- This is **RBAC at scale**: role defines access, not the individual

Step 6 — Apps Outside RBAC (Manager Form Flow)

- Some apps are sensitive or bespoke — not all roles get them automatically
- Manager submits a request form (Jira ticket, Okta Workflow form, or Service Desk form)

- IT reviews → approves → manually assigns or triggers provisioning
- These exceptions should be tracked as tech debt — if a pattern emerges, build a group rule

Step 7 — Manual Checklist Generation

- Automation triggers a checklist in Jira or Service Desk for tasks that can't be automated
- Examples: badge access, parking, building key card, desk assignment, hardware accessories
- Checklist is assigned to the correct owner (facilities, IT, manager)

Step 8 — Laptop Staging and First Day Prep

- MDM (Kandji/Jamf for Mac, Intune for Windows) enrolls device during staging
- Configuration profiles, required apps, and compliance policies push automatically
- Laptop is named, tagged in asset management, and assigned to user record
- Device is ready before day one — user boots up and Okta Verify enrollment is first prompt

Key talking point: The entire onboarding chain is triggered by a single HRIS event. IT's job is to build the automation once and monitor it — not to manually run it every time.

2. Okta Offboarding [Required Skill]

Core Framing

Offboarding is onboarding in reverse. The same HRIS-to-Okta integration that provisions access deprovisions it. Speed is a security requirement — every hour between termination and account deactivation is an open window.

The Offboarding Cascade

- **Step 1 — HRIS deactivation triggers the workflow:** HR marks employee as terminated
- **Step 2 — Okta deactivates the account:** user can no longer authenticate to any Okta-federated app
- **Step 3 — Group memberships removed:** RBAC rules no longer apply → all group-based app access revoked
- **Step 4 — App access removed:** direct app assignments also removed; SCIM sends deprovisioning payload to each app
- **Step 5 — Laptop lockdown:** MDM sends remote lock or wipe command; device marked 'pending return' in asset management
- **Step 6 — Data preservation:** Google Drive/email forwarded or transferred per policy before deletion
- **Step 7 — Account deletion or archival:** Okta account suspended for retention period, then deleted

Why Speed Matters

- Disgruntled employees may attempt data exfiltration in the gap between termination and deactivation
- Compliance frameworks (SOC 2, ISO 27001) require documented, timely deprovisioning
- Target: **account deactivated within 15 minutes of HR action**

What to Watch For

- Apps **not connected via SCIM** require manual deprovisioning — maintain a checklist
- Shared accounts or service accounts the employee owned — rotate credentials immediately
- Slack, GitHub, AWS — verify these are revoked even if not Okta-federated

Interview framing: 'Offboarding is onboarding in reverse — the same HRIS trigger that created the account terminates it. The goal is to close every access door in one automated sweep, with a manual checklist for the exceptions.'

3. SAML vs SCIM [Required Skill]

SAML — Authentication Protocol

SAML (Security Assertion Markup Language) is how Okta proves to an app that a user is who they say they are. It is an **authentication and authorization** protocol — not provisioning.

- **Okta acts as the Identity Provider (IdP)**; the app is the Service Provider (SP)
- Flow: user logs in → Okta authenticates → Okta sends signed **XML assertion** to the app
- App validates the assertion signature using Okta's **metadata/certificate**
- If valid → user is granted access. If not → login fails
- Setup requires exchanging metadata: download from Okta, upload to app (and vice versa)

What Breaks SAML and How to Fix It

- **Expired certificate**: Okta's signing cert has a validity period — download new metadata from Okta, re-upload to app
- **Metadata mismatch**: SP metadata out of sync with Okta config — re-export and re-import both sides
- **Clock skew**: SAML assertions have timestamps — servers more than a few minutes apart will reject assertions
- **Attribute mapping error**: app expects specific claim names — verify in Okta app settings under 'SAML attributes'

SCIM — Provisioning Protocol

SCIM (System for Cross-domain Identity Management) is how Okta creates, updates, and deletes user accounts in downstream apps. It is **provisioning** — not authentication.

- **Okta pushes user data to the app** via SCIM API calls (JSON payloads)
- On create: Okta sends user attributes → app creates account
- On update: attribute change in Okta → SCIM payload updates the app
- On deactivation: Okta sends deprovisioning call → app deactivates or deletes user
- Requires a **SCIM bearer token** from the app — stored in Okta integration settings

What Breaks SCIM and How to Fix It

- **Expired token**: regenerate in the app, update in Okta integration → test provisioning
- **Payload mapping drift**: app renamed an attribute field — verify field names in Okta's attribute mapping screen
- **App-side permission error**: SCIM token may have lost scope — regenerate with correct permissions

When to Use Each

	SAML	SCIM
--	------	------

Purpose	Authentication (who you are)	Provisioning (creating/managing accounts)
Direction	App pulls assertion from Okta	Okta pushes user data to app
Protocol	XML over HTTPS redirect	REST API / JSON
Used for	SSO login flow	Auto-create/update/deactivate users
Common failure	Expired cert / metadata mismatch	Expired token / attribute mapping drift

4. Integration Troubleshooting — Step by Step [Required Skill]

The Diagnostic Framework

When an app integration breaks, follow this sequence. **Start with logs before touching any configuration.** Changing settings before you understand the failure often makes diagnosis harder.

Step 1 — Check Okta System Logs

Go to Reports → System Log. Filter by the affected app and the time the issue started. Ask: 'When exactly did it stop working? What changed around that time?' Look for authentication failures, provisioning errors, or policy changes.

Step 2 — Check SAML Assertions or SCIM Payloads

For SAML: use the SAML Tracer browser extension or Okta's built-in diagnostic tools to capture the assertion. Verify the signature, the audience, and the attributes being sent. For SCIM: check the provisioning logs under the app's Provisioning tab for payload errors or 4xx/5xx responses.

Step 3 — Check Both Sides of the Integration

Okta's logs show what it sent. The app's logs show what it received (or rejected). Common gap: Okta shows success, but app rejected it silently. Always check the app's own admin console or logs.

Step 4 — Replace Expired Cert or Token

If SAML: download fresh metadata from Okta, re-upload to the SP. Download fresh SP metadata, re-upload to Okta. If SCIM: regenerate the API token in the app, update it in the Okta integration settings, then test provisioning.

Step 5 — Open Support Ticket in Parallel

If the issue isn't resolved in 15–20 minutes of diagnosis, open a ticket with the app vendor OR Okta support in parallel while continuing to investigate. Don't wait until you're stuck to file the ticket.

Key principle: 'Logs first, changes second.' Never reconfigure an integration based on a hunch. The logs will tell you exactly what failed and when — use them.

5. RBAC Rule Logic [Required Skill]

Core Structure

RBAC (Role-Based Access Control) in Okta is implemented through Group Rules. Group Rules evaluate user profile attributes and automatically assign users to groups — which then grant app access. The goal is **zero manual group membership**.

Rule Syntax

- **IF** [attribute] **AND** [attribute] → assign to group
- **IF** [attribute] **AND NOT** [attribute] → assign to group
- Rules support: equals, contains, starts with, regex
- Multiple conditions joined with **AND / OR**

Real-World Examples

Rule Name	Condition Logic
Austin Engineering FTEs	location = 'Austin' AND department = 'Engineering' AND employeeType != 'Contractor'
All Contractors	employeeType = 'Contractor'
Sales Team — US Only	department = 'Sales' AND countryCode = 'US'
Managers Only	title CONTAINS 'Manager' OR title CONTAINS 'Director'
New Hires (first 90 days)	daysFromHire <= 90 [requires custom attribute]

Why Manual Membership = Tech Debt

- **Manual assignment drifts** — people leave groups they shouldn't, or stay in ones they should have left
- Every manual membership is a future support ticket waiting to happen
- Audits become painful when access can't be explained by a rule
- **Rule of thumb:** if you can write a rule for it, you should

Exception handling: When an edge case doesn't fit a rule, use a dedicated group (e.g., 'manual-overrides-app-name') and document who is in it and why. This keeps exceptions visible and auditable.

6. Google Workspace Administration [Required Skill]

User Lifecycle Management

- **Create:** Admin Console → Users → Add New User. Set OU, primary email, recovery email
- **Suspend:** removes access without deleting data — standard for offboarding
- **Delete:** permanent — always transfer Drive/Gmail data first. Requires confirmation step
- Bulk operations: use CSV import for mass user creation during migrations or acquisitions

Organizational Unit (OU) Structure

- OUs organize users for applying different policies (e.g., 2FA exemptions, app access)
- Typical structure: /Company → /Departments → /Contractors, /Employees
- Policy inheritance: child OUs inherit parent settings unless overridden
- OU changes take effect within minutes but can take up to 24 hours to fully propagate

App Access Control

- Apps are enabled/disabled per OU in Admin Console → Apps → Google Workspace / Additional Google Services
- Third-party apps: control OAuth scopes and API access under Security → API Controls
- **Google Groups** can be used to grant access to Shared Drives, calendar resources, and distribution lists

Security Settings

- **2-Step Verification enforcement:** Security → Authentication → 2-Step Verification → Enforce for all users
- **Session controls:** set session length for Google services and third-party apps
- **Login challenges:** suspicious activity detection can require additional verification
- **Password policies:** minimum length, reuse rules, require strong password

Shared Drives and Permissions

- Shared Drives are owned by the org, not individuals — data persists after employee departure
- Membership roles: Manager, Content Manager, Contributor, Viewer
- Sharing policies: restrict external sharing at OU or org level
- DLP policies can flag or block sharing of sensitive content

Audit Logs and Reporting

- Admin Console → Reporting → Audit → Admin (admin actions), Login (auth events), Drive (file activity)
- Alert Center for security-critical events (suspicious login, data exfiltration signals)
- BigQuery export for long-term log retention and custom queries

Integration with Okta

- Google Workspace integrates with Okta via **SAML** (SSO) and **SCIM** (provisioning)
- Okta provisions/deprovisions users directly into Google Workspace
- Google OU assignment can be driven by Okta group membership via SCIM attribute mapping
- Okta becomes the IdP — Google authentication is delegated to Okta Verify/MFA

7. Microsoft 365 Exposure

M365 Admin Center Basics

- **User management:** create, edit, delete users; reset passwords; assign licenses
- **License assignment:** assign M365 Business/Enterprise licenses per user or group
- **Groups:** Microsoft 365 Groups, Security Groups, Distribution Lists — each has different capabilities
- **Exchange admin:** mailbox management, shared mailboxes, mail flow rules

Azure AD / Entra ID Fundamentals

- **Azure Active Directory** (now Entra ID) is Microsoft's cloud identity platform — analogous to Okta
- Supports SAML, OIDC, OAuth 2.0 for SSO to apps
- **Conditional Access policies:** require MFA, block legacy auth, restrict by location or device compliance
- **Groups-based licensing:** assign licenses via group membership (mirrors RBAC concept from Okta)
- **App registrations:** register custom apps for SSO/API access

Similarities vs Google Workspace

Concept	Google Workspace	Microsoft 365 / Entra ID
User management	Admin Console → Users	M365 Admin Center / Entra ID
Groups for access	Google Groups / OUs	Security Groups / M365 Groups
SSO federation	SAML via Okta IdP	SAML/OIDC via Okta or Entra ID
MDM integration	Android Enterprise / BeyondCorp	Intune / Endpoint Manager
Audit logs	Admin Audit Log	Unified Audit Log / Entra Sign-ins
MFA enforcement	2SV policy in Admin Console	Conditional Access in Entra ID

Key talking point: 'My primary experience is with Google Workspace and Okta, but the admin concepts transfer directly. User lifecycle, group-based access, MFA enforcement, and audit logging work the same way — just different consoles. I'm comfortable picking up M365 quickly.'

8. MDM — macOS and Windows [Required Skill]

macOS MDM — Kandji and Jamf

- **Kandji:** modern, blueprint-based MDM. Each blueprint = a set of profiles and enforcements for a device group
- **Jamf Pro:** enterprise-grade, highly configurable. Uses policies, scripts, and configuration profiles
- **Configuration profiles:** enforce Wi-Fi, VPN, FileVault encryption, screen lock, software update restrictions
- **App deployment:** push apps silently via MDM catalog (Kandji) or Self Service (Jamf) — no user action required
- **Enforcement policies:** require OS version minimums, block USB storage, enforce disk encryption
- **Scripts:** run shell scripts on enrollment, on schedule, or on trigger (Jamf policies)

Windows MDM — Microsoft Intune

- **Intune:** Microsoft's cloud-based MDM, integrated with Entra ID / Azure AD
- **Device enrollment:** Azure AD join + Intune enrollment during Windows Autopilot or manual setup
- **Compliance policies:** require BitLocker, antivirus, minimum OS version, password complexity
- **Configuration profiles:** push registry settings, Wi-Fi, VPN, Edge browser settings
- **App deployment:** deploy Win32 apps, MSI packages, or Microsoft Store apps
- **Conditional Access integration:** non-compliant devices can be blocked from M365 resources

Device Enrollment Workflows

- **User-initiated:** user enrolls device manually via Company Portal or MDM profile download
- **Zero-touch (macOS):** ABM (Apple Business Manager) + Kandji/Jamf. Device purchased, added to ABM, MDM server assigned. On first boot → MDM enrollment automatic
- **Zero-touch (Windows):** Windows Autopilot. Device hardware hash registered. Shipped directly to user. User powers on → Azure AD join + Intune auto-enrolls
- Zero-touch requires vendor coordination: Apple Authorized Reseller or Microsoft partner for hardware hash upload

Offboarding Device Actions

- **Remote lock:** secure the device immediately, display contact info on screen
- **Remote wipe:** factory reset, removes all data — use for departing employees or lost devices
- **Selective wipe (BYOD):** removes only corporate apps/data, leaves personal content intact
- **Remove from MDM:** unenroll device before reassigning; re-enroll under new user

Asset Tracking in MDM

- Both Kandji and Jamf display hardware info: serial number, model, OS version, last check-in time
- Serial number = primary asset identifier — sync to asset management system

- Use MDM inventory as the source of truth for deployed device status

9. Jira and Confluence [Required Skill]

Jira — Ticket Management

- **Queue management:** organize IT tickets by type, priority, and SLA tier
- **Workflow states:** Open → In Progress → Pending → Resolved → Closed
- **Priority tiers:** P1 (critical/business-down) → P2 (high impact) → P3 (standard) → P4 (low)
- **SLA awareness:** track time-to-first-response and time-to-resolution. Escalate before breach
- **Components and labels:** tag tickets by system (Okta, MDM, Google) for reporting and pattern detection
- **Automation rules:** auto-assign by issue type, auto-transition on comment, notify on SLA breach
- **Subtasks:** break complex onboarding/offboarding tickets into trackable steps

Confluence — Documentation

- **Knowledge base structure:** Space → Page hierarchy. Organize by team and topic
- **Runbooks:** step-by-step operational procedures for common IT tasks
- **SOPs:** Standard Operating Procedures — document once, reference forever
- **Onboarding docs:** new employee guides, IT setup checklists, software request process
- **Incident post-mortems:** document what broke, why, how it was fixed, and what prevents recurrence
- **Templates:** create page templates for runbooks, post-mortems, and change requests for consistency

Using Both Together for IT Ops

- Link Jira tickets to Confluence runbooks — ticket includes a 'how-to' link for the responder
- Post-incident: close the Jira ticket AND write/update the Confluence runbook
- Onboarding/offboarding: Jira = the checklist instance; Confluence = the process documentation

Key talking point: 'Documentation is a force multiplier. Every runbook I write means the next person who hits that issue resolves it in 5 minutes instead of 45. Good docs also make it safe to take a vacation.'

10. Asset Management and Procurement [Required Skill]

Hardware Lifecycle

- **Procurement:** Submit purchase order, vendor selection, budget approval. Standard: MacBook Pro/Air for engineering, MacBook Air for general staff, Windows for specific roles
- **Receiving and Tagging:** Verify serial numbers, apply asset tags, log in asset management system (Snipe-IT, Jamf, or spreadsheet)
- **Staging:** Enroll in MDM, apply configuration profiles, install required apps, name device per naming convention
- **Deployment:** Assign to user in MDM and asset system, deliver with accessories, confirm enrollment and policy compliance
- **Refresh:** Typically on 3–4 year cycle. Evaluate device performance, OS support end-of-life, battery health
- **Offboarding:** Collect from departing employee, wipe, unenroll from MDM, mark 'available' or 'decommissioned' in asset system

Tracking and Inventory

- Serial number is the canonical asset identifier — use it everywhere
- **MDM** provides real-time device state; **asset management system** tracks ownership and location history
- Regular audits: reconcile MDM inventory against asset records quarterly
- **Loaner management:** maintain a pool of spare devices. Track with check-out/check-in log

Vendor Coordination

- Maintain approved vendor list: Apple (direct or authorized reseller), Dell, Lenovo
- For Apple: work with authorized reseller to register devices to ABM for zero-touch enrollment
- Lead times matter — order 2–3 weeks before hire date for new headcount
- Purchase orders: understand your org's approval threshold. Know when to loop in finance

Key talking point: 'Asset management is an extension of onboarding and offboarding. The same automation that provisions access also triggers staging a device. The same offboarding workflow that revokes access triggers the device collection and wipe process.'

11. Security Best Practices [Required Skill]

MFA Enforcement

- **Enforce MFA for all users, all apps, no exceptions** — including IT admins (especially IT admins)
- Use Okta Verify with biometric or push — avoid SMS OTP for privileged accounts (SIM swap risk)
- Authentication policies in Okta: require phishing-resistant MFA for admin access
- Step-up authentication: require re-verification for sensitive operations (password reset, admin app access)

Least Privilege Access Principle

- Users get **only** the access their role requires — nothing more by default
- Enforce through RBAC group rules — access requires a justification (role attribute)
- Privileged access (admin roles, production systems) requires separate approval workflow
- Periodic access reviews: verify that access is still justified quarterly or semi-annually

Okta Authentication Policies

- **Authentication policies:** define which MFA factors are required for which apps
- **Device trust:** require managed device (MDM-enrolled) for access to sensitive apps
- **Network zone restrictions:** block access from unexpected geolocations or allow only corporate IPs for admin console
- **Session policies:** set session lifetime and idle timeout per application risk level

Offboarding as a Security Event

- Treat every offboarding as a potential security incident — act fast
- Target: **Okta account deactivated within 15 minutes of HR notification**
- Document time from termination to deactivation for compliance reporting
- For involuntary terminations: have IT on standby — coordinate deactivation to coincide with the HR conversation

Audit Logs and Access Reviews

- Enable and retain Okta system logs (recommend 12-month retention minimum)
- Regular log reviews: look for impossible travel, unusual login hours, privilege escalation attempts
- Access review cadence: quarterly for privileged users, semi-annual for general access
- Integrate logs with SIEM (Splunk, Datadog, Elastic) for alerting and correlation

Zero Trust Framing

- **Verify every user:** MFA on every authentication, no implicit trust
- **Verify every device:** device trust policies — only managed, compliant devices access sensitive resources
- **Verify every access request:** least privilege + just-in-time access for privileged roles

- Network perimeter is gone — identity is the new perimeter

12. Ticket Prioritization and Help Desk Communication [Required Skill]

Triaging Multiple Urgent Tickets

- **First pass:** scan all new tickets in under 2 minutes. Identify any P1s (business-down, executive-blocked)
- **Impact vs Urgency matrix:** High impact + High urgency = P1. High impact + Low urgency = P2. Triage accordingly
- **Look for patterns first:** 10 tickets about email? Likely a systemic issue. Fix the root cause, not 10 individual tickets
- **Acknowledge everything within 15 minutes:** even 'I received this and am looking into it' reduces anxiety and sets expectations
- **Delegate or escalate:** if queue is overwhelming, surface to team lead and redistribute

Impact vs Urgency Matrix

	High Urgency	Low Urgency
High Impact	P1 — Drop everything	P2 — Address today
Low Impact	P3 — Queue normally	P4 — When capacity allows

Communicating with Executives

- Executives want: **What happened, what you're doing, when it will be fixed**
- Skip the technical cause — they don't need it and it erodes confidence
- Lead with impact, not diagnosis

Template: "Your [system] is [experiencing issue]. This is affecting [scope]. I am [action being taken] and expect resolution by [time]. In the meantime, here is your workaround: [simple step]."

Example: "Your email is delayed due to a routing configuration update. It will be fully restored by 3:00 PM today. In the meantime, you can access email via the web browser at mail.google.com."

13. Interview Performance Tips

Say 'I don't know' when you don't know

Interviewers respect honesty and can tell when you're guessing without flagging it. It builds trust. Follow with 'but here's how I'd find out' when possible.

Educated guesses are fine — flag them as guesses

There's a difference between 'I'm not certain, but I believe SCIM uses REST/JSON' and stating it as fact. Flag uncertainty and it becomes a strength.

Pause before answering — form your first point, then speak

Silence is not weakness. Two seconds of thinking produces a structured answer. Rambling while thinking produces a weak one.

Stop when your answer is done — don't fill silence

The urge to keep talking after a complete answer is the enemy. A complete, clean answer followed by silence reads as confidence.

After the interview: log every question asked

Write them down within 30 minutes. Review the gaps. Study them before any follow-up round.

Mindset: This interview is a conversation between two professionals, not a test. You are evaluating them as much as they are evaluating you. Bring curiosity and calm — you've done the prep work.

14. Quick Reference Card

Keep this card open during final review. These are the core mental models.

ONBOARDING FLOW

- HRIS trigger (BambooHR/Workday)
- → Webhook/API to Okta (or automation layer)
- → Okta account created (SCIM or API)
- → Group rules evaluate → RBAC auto-assigns
- → Apps provisioned via group membership
- → Manual checklist generated (Jira)
- → MDM enrolls laptop → Staged and delivered

OFFBOARDING FLOW

- HRIS deactivation event fires
- → Okta account deactivated (target: < 15 min)
- → Group memberships removed
- → All app access revoked (SCIM deprovisioning)
- → MDM sends remote lock/wipe
- → Asset marked 'pending return'
- → Account suspended → archived per retention policy

SAML vs SCIM

- SAML = Authentication (who you are)
- XML assertion | Okta = IdP | App = SP
- Breaks: expired cert, metadata mismatch, clock skew
- Fix: re-pull metadata, re-upload both sides
- SCIM = Provisioning (create/update/delete users)
- REST/JSON payload | Okta pushes to app
- Breaks: expired token, attribute mapping drift
- Fix: regenerate token, verify field mappings

RBAC RULE LOGIC

- IF [attribute] AND [attribute] → assign group
- IF [attribute] AND NOT [attribute] → assign group
- Goal: ZERO manual group membership
- Rule of thumb: if you can write a rule for it, you should
- Manual assignment = drift = tickets = tech debt

INTEGRATION BROKEN

1. Check Okta System Log — when did it stop?
2. Check SAML assertion or SCIM payload
3. Check both sides (Okta logs + app logs)
4. Refresh expired cert or token
5. Open vendor/Okta support ticket in parallel

EXECUTIVE COMMUNICATION

- Format: Impact + Action + Timeline
- Skip: technical cause, jargon, uncertainty
- Template: "[System] is [issue]. I am [action]."
- Resolution by [time]. Workaround: [simple step]."

MDM QUICK REF

- macOS: Kandji (blueprints) | Jamf Pro (policies/scripts)
- Windows: Intune (compliance + config policies)
- Zero-touch Mac: ABM + MDM → auto-enroll on first boot
- Zero-touch Windows: Autopilot → AADJ + Intune auto-enroll
- Offboard: Remote lock → Wipe → Unenroll → Reassign

SECURITY BASELINE

- MFA: enforce for ALL users, ALL apps
- Least privilege: access requires a justified role
- Fast offboarding: < 15 min from HR action to deactivation
- Device trust: only managed devices access sensitive apps
- Audit logs: retain 12 months, review quarterly
- Zero trust: verify every user, every device, every access

15. Mock Q&A; — Practice Questions with Model Answers

Read each question, cover the answer, and respond aloud before checking. **Drill these until the answers feel like your own words, not memorized text.**

OKTA

Q: Walk me through how you would onboard a new employee in Okta end to end.

A: The process starts with the HRIS. When a new employee record is created in BambooHR or Workday, a webhook fires to our automation layer — either Okta Workflows or a middleware tool like Workato. That trigger creates the Okta account, and our group rules evaluate the user's department, location, and role attributes to auto-assign them to the right groups. Group membership drives app provisioning via SCIM. Any apps outside RBAC go through a manager request flow. In parallel, a Jira checklist generates for manual steps like badge access, and MDM starts staging the laptop. By day one, the user boots their machine, completes Okta Verify enrollment, and everything is ready.

Q: How would you structure groups in Okta to manage role-based access control?

A: I structure groups around roles, not individuals. Each group maps to a specific job function or access tier — for example, 'eng-team', 'sales-team', 'it-admin'. Groups are assigned apps, not users directly. Group membership is driven entirely by Okta Group Rules that evaluate profile attributes like department, title, and employeeType. That way, adding a new employee to the right department automatically grants the right access. No manual group assignment needed.

Q: An app integration broke overnight. Walk me through how you would troubleshoot it.

A: First, I go to Okta's System Log and filter for the affected app around the time it stopped working. I'm looking for authentication failures, provisioning errors, or any configuration changes. Next, I check whether it's SAML or SCIM — for SAML I'll capture an assertion and verify the cert and attribute mapping; for SCIM I'll check the provisioning logs for payload errors or expired tokens. I always check both sides: Okta's logs show what it sent, the app's logs show what it received. If I find an expired cert or token, I rotate it and test. If I'm not resolved in 20 minutes, I open a vendor support ticket in parallel while I keep investigating.

Q: What is the difference between SAML and SCIM and when would you use each?

A: SAML handles authentication — it's the protocol that lets a user log into an app through Okta SSO. Okta sends a signed XML assertion to the app, the app validates it, and the user gets in. SCIM handles provisioning — it's how Okta creates, updates, and deactivates user accounts in downstream apps automatically. You use SAML so users don't need separate passwords for each app, and SCIM so you don't have to manually manage user accounts in every system.

Q: How do you avoid manual group membership drift in Okta?

A: By writing group rules for everything I can. Okta Group Rules evaluate user profile attributes and assign group membership automatically, so there's no manual step to drift. If a use case doesn't fit a rule, I create a named exception group with documented membership and a Jira ticket to revisit it. I also run periodic access reviews to catch any manual assignments that crept in and convert them to rule-based access.

Q: Walk me through how you would offboard a terminated employee.

A: Offboarding is onboarding in reverse. The moment HR marks the employee terminated in the HRIS, a webhook fires to Okta and deactivates the account — my target is under 15 minutes from HR action. Deactivation removes all group memberships, which revokes group-based app access. SCIM then sends deprovisioning calls to each connected app. Any apps not on SCIM get manually revoked via a Jira checklist. Simultaneously, MDM sends a remote lock to the laptop and marks the device as pending return in the asset system.

Q: What is an authentication policy and why does it matter?

A: An authentication policy in Okta defines what factors are required to access a specific app or group of apps. For example, I might require phishing-resistant MFA for the admin console but allow push notification for lower-risk apps. Policies also enforce device trust — requiring that only MDM-managed devices can access sensitive systems. They matter because not all apps carry the same risk, and a one-size policy either over-restricts or under-secures. Authentication policies let you calibrate access to actual risk.

GOOGLE WORKSPACE

Q: How have you used Google Workspace admin in a previous role?

A: I've managed the full user lifecycle — creating, suspending, and deleting accounts, managing OU structure to apply different security policies by department, and controlling third-party app access through API controls. I've set up Google Groups for role-based access to Shared Drives and enforced 2-Step Verification org-wide. I also used the audit logs regularly to investigate suspicious login activity and file sharing events.

Q: How would you manage app access for different departments in Google Workspace?

A: I use a combination of OU structure and Google Groups. For broad policy differences — like contractors not getting access to certain Google services — I put them in a separate OU with those services disabled. For finer-grained app access, like Shared Drive membership or distribution lists, I use Google Groups. For third-party OAuth apps, I control which apps are trusted and what scopes they can access through the API Controls section.

Q: How do you enforce security policies across a Google Workspace org?

A: Through a combination of OU-level settings and org-wide policies. I enforce 2-Step Verification as mandatory for all users — no exemptions except specific service accounts. I set session length limits so that access doesn't persist indefinitely on unmanaged devices. For file sharing, I restrict external sharing to specific approved domains unless users request an exception. I also review the Alert Center regularly for

suspicious login patterns.

Q: How does Google Workspace integrate with Okta?

A: Okta integrates with Google Workspace via SAML for SSO and SCIM for provisioning. Okta becomes the identity provider — users authenticate through Okta, and Google accepts Okta's SAML assertion to grant access. On the provisioning side, Okta's SCIM integration creates and deactivates Google accounts based on Okta user status, and can set the OU assignment based on Okta group attributes. This means Google user management is largely automated through Okta.

MDM — macOS AND WINDOWS

Q: What MDM platforms have you worked with and what did you manage in them?

A: On the Mac side I've worked with Kandji and Jamf. In Kandji I use blueprints to manage configuration profiles, app deployments, and OS enforcement policies. In Jamf I've built policies and used scripts for more complex workflows. On Windows I've used Intune for device enrollment, compliance policies, and app deployment. Across both I manage the full device lifecycle — enrollment at staging through wipe at offboarding.

Q: Walk me through how you would enroll a new Mac into your MDM.

A: For zero-touch: the device is purchased through our Apple Authorized Reseller who registers the serial to our Apple Business Manager account. The ABM is connected to Kandji or Jamf, so when the device powers on for the first time it receives the MDM enrollment profile automatically. The user goes through setup, and by the time they're at the desktop our configuration profiles and required apps are already installing silently. For manual enrollment, I download the MDM enrollment profile and install it, or use Apple Configurator 2 for staging.

Q: How do you handle a device when an employee is terminated?

A: MDM is part of the offboarding automation. When the offboarding workflow fires, I send a remote lock command through MDM immediately to prevent the employee from accessing the device. Once the device is physically returned, I perform a remote wipe to factory reset it. Then I unenroll it from MDM, remove the user assignment in the asset management system, and mark it as available for reassignment or decommission.

Q: What is zero-touch enrollment and have you worked with it?

A: Zero-touch enrollment means a device arrives at the employee's door or desk and enrolls in MDM automatically on first boot — no IT hands-on required. For Macs, this works through Apple Business Manager: the reseller registers the device to ABM, ABM is connected to the MDM, and on first power-on the enrollment profile installs automatically. For Windows, it's Autopilot: the hardware hash is registered to Intune, and the device Azure AD joins and enrolls into Intune during initial setup. Yes, I've set this up and it's a major operational win for scaling without adding IT headcount.

SECURITY

Q: How do you think about least privilege access in your day to day work?

A: Least privilege means users start with nothing and earn access through their role, not through asking. In practice, I implement it through RBAC group rules in Okta — your job function determines your access automatically. For anything above standard access, I require a manager approval workflow and time-bound grants where possible. I also run quarterly access reviews to catch access that was granted but is no longer justified.

Q: What steps do you take when an employee is terminated from a security standpoint?

A: Speed is the priority. I coordinate with HR so that IT is ready to act the moment termination is confirmed — for involuntary exits we're standing by. The HRIS event fires, Okta deactivates the account, SCIM deprovisions app access across all connected systems. Any non-SCIM apps get manually revoked via checklist. MDM locks the device. I document the time from termination to full deactivation for our compliance records. Any shared credentials the employee had access to get rotated immediately.

Q: How do you enforce MFA across your org?

A: In Okta, I use authentication policies to require MFA for all apps — no exceptions. I prefer Okta Verify with push or biometric over SMS because of SIM swap risk. For admin access I require phishing-resistant factors like hardware keys or passkeys where supported. In Google Workspace I enforce 2-Step Verification at the OU level with no exemption. New users are prompted to enroll MFA on their first login, and accounts can't fully activate until enrollment is complete.

HELP DESK AND COMMUNICATION

Q: How do you prioritize multiple urgent tickets coming in at the same time?

A: I do a fast first pass on all incoming tickets before touching any of them — I'm looking for anything that's business-down or blocking an executive. Then I apply the impact vs urgency matrix: high impact plus high urgency gets immediate attention, everything else queues in order. Critically, I look for patterns — if multiple people are reporting the same issue, I treat it as one systemic incident rather than individual tickets. I acknowledge everything within 15 minutes even if I can't resolve it yet, because a silent ticket creates more anxiety than a slow one.

Q: How would you explain a technical issue to a non-technical executive?

A: I use the impact-action-timeline format and skip the technical cause entirely. Something like: 'Your calendar invites are not sending. I'm resolving a configuration issue and expect it fixed by 2 PM. In the meantime, you can send invites directly from your phone.' The executive wants to know if they need to reschedule their day — not why DNS propagation is inconsistent. I keep it under three sentences.

Q: Tell me about a time an integration or system broke. How did you identify and fix it?

A: We had a SAML integration to our expense management platform stop working overnight — users were getting authentication errors. I pulled Okta's system log first and saw failed SAML assertions timestamped around 11 PM, which matched a scheduled cert rotation window. I confirmed the app's signing cert had been auto-renewed on Okta's side but the SP hadn't received updated metadata. I re-exported the metadata from Okta, uploaded it to the expense platform's SSO settings, and tested. Login was restored in about 20 minutes. I documented the fix and set a calendar reminder 30 days before the next cert expiry.

ASSET MANAGEMENT

Q: Walk me through your hardware lifecycle process from procurement to offboarding.

A: It starts with procurement — I submit a PO through our vendor, ensuring the reseller registers devices to Apple Business Manager for zero-touch. When devices arrive I verify serials, tag them, and log them in the asset system. Staging means enrolling in MDM, applying profiles and apps, and naming the device. I assign to the user, deliver, and confirm MDM enrollment and compliance. At refresh time — typically every 3-4 years — I evaluate battery and performance metrics from MDM to prioritize replacements. At offboarding, the device is locked via MDM, collected, wiped, unenrolled, and marked available for reassignment.

Q: How do you track and manage IT assets across a growing organization?

A: MDM is the live source of truth for device state — OS version, last check-in, compliance. Asset management (whether that's Snipe-IT, a Jamf record, or a dedicated tool) tracks ownership history, purchase dates, and location. The serial number is the link between both. I run quarterly reconciliation: compare MDM inventory to the asset system and investigate any gaps. As the org grows, the key is automation — MDM enrollment automatically creates the asset record so nothing gets missed. I also maintain a loaner pool with a check-out/check-in log for temporary devices.

BEHAVIORAL / SITUATIONAL

Q: Tell me about a time you had to learn something technical quickly. How did you approach it?

A: When I was first handed ownership of our Okta environment I had hands-on experience but hadn't managed it solo before. I broke the learning down: I spent the first week on the current config — documented what existed, understood why each group rule and policy was there. I ran through Okta's admin certification material in parallel. I identified the three most likely failure points and made sure I knew how to diagnose and resolve each one. Within two weeks I was making configuration changes confidently. The approach is always: understand what exists before building anything new.

Q: Describe a time you improved or automated a manual IT process.

A: Our onboarding process was almost entirely manual — IT received a Slack message when someone was hired, then manually created accounts, assigned apps, and generated a checklist by hand. I mapped out

every step, identified which ones were rule-based, and built group rules in Okta to handle RBAC automatically. I connected BambooHR to Okta Workflows to trigger account creation from HRIS events. I replaced the manual checklist with a Jira automation that generated the ticket with subtasks on trigger. Total manual IT time per hire went from about 45 minutes to under 5 minutes for standard roles.

Q: How do you stay current with new tools and technologies?

A: I follow vendor release notes for Okta, Kandji, and Google Workspace — they publish changelogs and I have them in an RSS reader. For broader trends I follow a handful of IT ops and identity security communities. When I hear about a new tool I try to get hands on with it in a sandbox or trial before evaluating whether it solves a real problem. I also stay connected to peers in the space — sometimes a 10-minute conversation with someone who's already implemented something saves two weeks of research.

Q: What does good IT documentation look like to you and why does it matter?

A: Good documentation is something a new team member can follow without asking anyone a question. It has a clear purpose statement, numbered steps with expected outcomes at each step, and a 'what to do if this breaks' section. It lives in a searchable system — Confluence — not in someone's head or a personal doc. It matters because documentation is a force multiplier: a well-written runbook means the second person to hit an issue resolves it in 5 minutes instead of 45. It also means the team can operate safely when any one person is out.

16. Questions to Ask the Interviewer

Ask 2–3 of these at the end of the interview. Choose based on what's come up in conversation. **These signal strategic thinking, not just job-seeking.**

Question 1 — On automation maturity

"Where would you say the team sits on the spectrum from mostly manual to fully automated for onboarding and offboarding? And what's the biggest blocker to moving further along that spectrum?"

Why this works: This shows you're thinking about the gap between current state and ideal state — and that you're already thinking about how to close it.

Question 2 — On IT and engineering collaboration

"How does the IT team collaborate with engineering right now? Are there shared tools, shared runbooks, or joint ownership of things like identity and access infrastructure?"

Why this works: This reveals whether IT is a service desk or a technical peer to engineering — and whether you'd have room to do real infrastructure work.

Question 3 — On 90-day success

"What would success look like at 90 days for someone in this role? What's the difference between someone who's doing the job and someone who's already making the team better?"

Why this works: This frames you as someone who thinks in outcomes, not tasks. It also gives you a roadmap if you get the offer.

Question 4 — On AI and tooling direction

"Is the team thinking about how AI tooling fits into IT operations — things like AI-assisted ticket routing, automated diagnostics, or workflow generation? Where does that conversation stand right now?"

Why this works: This signals forward-thinking awareness without overclaiming. It also shows genuine curiosity about where the company is heading.

Question 5 — On biggest infrastructure challenges

"What's the biggest infrastructure or identity challenge the team is working through right now that the person in this role would be expected to contribute to?"

Why this works: This is the most valuable question you can ask. The answer tells you exactly what the real job is — not just what's in the job description.

Final reminder: You don't have to ask all five. Pick the two that align most naturally with what came up in the conversation. A question that connects back to something they said earlier is worth more than any question from this list.